Detekcia phishingových e-mailov pomocou transformátorových modelov

Marek Homiak, Marko Olejník, Hugo Juraj Bulinský a Adrián Polák

Technická Univerzita v Košiciach

Abstrakt Táto práca sa zaoberá detekciou phishingových e-mailov pomocou transformátorových modelov. Porovnávame všeobecný model *BERT-base-uncased* s doménovo špecifickým modelom *CySecBERT* [1], predtrénovaným na kyberneticky orientovaných textoch. Na datasete *zefang-liu/phishing-email-dataset* [4] z platformy Hugging Face sme fine-tunovali oba modely na binárnu klasifikáciu (Safe Email vs. Phishing Email) a hodnotili ich pomocou metrík Accuracy, F1, Precision, Recall a ROC-AUC. Na in-distribution testovacej množine CySecBERT prekonáva BERT o +1,02 pp v skóre F1 a +0,09 pp v ROC-AUC. Analýza generalizácie na externom datasete odhalila výrazný pokles presnosti u oboch modelov, avšak ROC-AUC zostalo nad 0,93, čo naznačuje robustné naučené reprezentácie. Analýza chýb pomocou LIME identifikovala kľúčové výrazy zodpovedné za falošné pozitívy a falošné negatíva.

Keywords: phishing detekcia · BERT · CySecBERT · transformátory · klasifikácia textu · kybernetická bezpečnosť

1 Formulácia problému

Phishing patrí k najrozšírenejším formám kybernetických útokov. Útočníci sa vydávajú za dôveryhodné subjekty s cieľom získať citlivé údaje, poverenia alebo finančné prostriedky. Automatizovaná detekcia phishingových e-mailov preto predstavuje kľúčovú zložku moderných bezpečnostných systémov.

Cieľom tejto práce je navrhnúť, natrénovat a vyhodnotiť klasifikátor phishingových e-mailov na báze transformátorových modelov. Konkrétne riešime nasledujúce otázky:

1. Dokáže doménovo špecifický model CySecBERT prekonať všeobecný model BERT-base-uncased na úlohe detekcie phishingových e-mailov?
2. Aké sú typické vzory chýb (falošné pozitívy a falošné negatíva) a aké výrazy ich najviac ovplyvňujú?
3. Sú natrénované modely robustné voči externým (neviditeľným) dátam?

Problém je formulovaný ako binárna klasifikácia textu: vstupom je surový text e-mailu a výstupom je predikcia triedy *Phishing Email* (1) alebo *Safe Email* (0).

2 Teoretický background

2.1 Transformátorové modely pre spracovanie prirodzeného jazyka

Architektúra Transformer [6] revolucionalizovala spracovanie prirodzeného jazyka (NLP) zavedením mechanizmu pozornosti (self-attention), ktorý umožňuje modelu zachytiť dlhodobé závislosti v texte bez rekurentných vrstiev.

2.2 BERT

BERT (Bidirectional Encoder Representations from Transformers) [2] je predtrénovaný jazykový model, ktorý číta text obojsmerne (zľava doprava aj sprava doľava súčasne). Predtrénovanie prebieha na dvoch úlohách: Masked Language Modeling (MLM) a Next Sentence Prediction (NSP). Vďaka tomu BERT zachytáva bohatý kontextový obsah slov, čo ho robí vynikajúcim základom pre dolaďovanie (fine-tuning) na downstream úlohách. My používame variant *bert-base-uncased* s 12 Transformer blokmi, 768 skrytými jednotkami a 110M parametrami.

2.3 CySecBERT

CySecBERT [1] je doménovo špecifická varianta BERT-u, ktorá bola ďalej predtrénovaná na rozsiahlom korpuse kyberneticky orientovaných textov (bezpečnostné správy, CVE záznamy, správy o malvéri, phishingové e-maily). Tým model nadobúda hlbšie porozumenie pre odborný slovník kybernetickej bezpečnosti — výrazy ako *credentials*, *verify your account* alebo *suspend* sú v tomto kontexte silnými signálmi phishingu.

2.4 Fine-tuning pre sekvenčnú klasifikáciu

Fine-tuning pre klasifikáciu textu spočíva v pridaní lineárnej klasifikačnej hlavy na vrchol CLS tokenu BERT-u, pričom celá sieť sa dolaďuje na cieľovom datasete pomocou cross-entropy straty [2].

2.5 Metriky hodnotenia

Na vyhodnotenie modelov používame nasledujúce metriky:

- **Accuracy** — podiel správne klasifikovaných príkladov.
- **Precision** — podiel skutočných phishingov spomedzi predikovaných phishingov.
- **Recall** — podiel zachytených phishingov spomedzi všetkých skutočných phishingov.
- **F1-score** — harmonický priemer Precision a Recall.
- **ROC-AUC** — plocha pod krivkou ROC, miera schopnosti modelu rozlišovať triedy.

3 Popis datasetu a predspracovanie dát

3.1 Popis datasetu

Na experimentovanie sme použili dataset `zefang-liu/phishing-email-dataset` dostupný na Hugging Face Hub [4]. Dataset obsahuje e-maily označené binárnou triedou:

- **Safe Email** (trieda 0) — legitímne e-maily.
- **Phishing Email** (trieda 1) — phishingové e-maily.

Dataset vykazuje miernu nerovnováhu tried v prospech phishingových e-mailov, čo je charakteristické pre reálne prostredie.

3.2 Predspracovanie dát

Predspracovanie zahŕňalo tieto kroky:

1. Odstránenie riadkov s chýbajúcimi hodnotami.
2. Odstránenie stĺpca `Unnamed: 0`.
3. Premenovanie stĺpcov na `text` a `label`.
4. Čistenie textu: nahradenie zalomení riadkov medzerami, odstránenie nadbytočných bielych znakov (`re.sub`).
5. Zakódovanie cieľovej premennej: *Safe Email* $\rightarrow$ 0, *Phishing Email* $\rightarrow$ 1.
6. Odstránenie duplikátov po čistení textu.

3.3 Rozdelenie dát

Dataset bol rozdelený stratifikovanou náhodnou vzorkou so seedom 42 na:

- **Trénovaciu množinu**
- **Validačnú množinu**
- **Testovaciu množinu**

Stratifikácia zaručuje rovnomerné zastúpenie tried vo všetkých troch množinách. Bol overený nulový prienik medzi trénovacou a testovacou množinou.

4 Metodológia

4.1 Architektúra riešenia

Oba modely (BERT a CySecBERT) boli fine-tunované na binárnu sekvenčnú klasifikáciu pomocou knižnice Hugging Face `Transformers` [7]. Vstupné texty boli tokenizované s maximálnou dĺžkou 128 tokenov (s orezaním dlhších textov a paddingom kratších), pričom každý model mal vlastný tokenizátor:

- BERT: `bert-base-uncased` tokenizátor (WordPiece, 30 522 podslová).
- CySecBERT: `markusbayer/CySecBERT` tokenizátor (rozšírená doménová slovná zásoba).

4.2 Hyperparametre tréningu

Trénovacie argumenty boli zvolené s ohľadom na stabilitu a reprodukovateľnosť (Tab. 1). Reprodukovateľnosť bola zaistená fixovaním seedov vo všetkých knižniciach (`random`, `numpy`, `torch`, `CUDA`) a nastavením `torch.use_deterministic_algorithms(True)`.

Tabuľka 1: Hyperparametre tréningu pre oba modely.

Hyperparameter	BERT-base-uncased	CySecBERT
Počet epoch	3	3
Learning rate	1×10^{-5}	1×10^{-5}
Batch size (train / eval)	32	32
Max. dĺžka sekvencie	128	128
Warmup ratio	—	0,1
Evaluačná stratégia	každá epocha	každá epocha
FP16 (mixed precision)	áno	áno

CySecBERT má navyše warmup ratio 0,1, čo zodpovedá 10 % krokov s postupným nárastom learning rate — štandardná technika pri fine-tunovaní BERT-u.

4.3 Implementácia

Kód implementuje vlastnú triedu `EmailDataset` (dediaca od `torch.utils.data.Dataset`) a funkciu `evaluate_model` v module `utils.py`. Tréner (`Trainer`) z Hugging Face automaticky vyberá najlepší checkpoint na základe validačnej accuracy (`load_best_model_at_end=True`).

5 Návrh experimentov

5.1 Kontrolovaný experiment: BERT vs. CySecBERT (ablation study)

Hlavným kontrolovaným experimentom je porovnanie modelu BERT-base-uncased (baseline) s CySecBERT za totožných podmienok:

- Rovnaký dataset, rovnaké rozdelenie, rovnaký seed (42).
- Rovnaké hyperparametre (okrem warmup pre CySecBERT).
- Rovnaká evaluačná pipeline (metriky, testovacia množina).

Táto konfigurácia umožňuje priamo merať efekt doménovej predtrénovacej špecializácie pri inak identických podmienkach.

5.2 Analýza chýb

Na porozumenie zlyhaniam modelov sme:

1. Extrahovali falošné pozitívy (FP: Safe → Phishing) a falošné negatíva (FN: Phishing → Safe).
2. Použili TF-IDF na identifikáciu top-20 fráz charakteristických pre FP a FN skupiny.
3. Aplikovali LIME (*Local Interpretable Model-agnostic Explanations*) [5] na 10 FN a 10 FP príkladov CySecBERT-u s agregovaním priemerných váh.

5.3 Test generalizácie na externom datasete

Ako doplnkový experiment sme natrénované modely otestovali na externom datasete `phishing_email.csv` (80 106 e-mailov, 24 032 testovacích vzoriek), ktorý pochádza z iného zdroja ako trénovací dataset. Ide predovšetkým o Enron-style firemné e-maily, čo predstavuje výraznú distribučnú zmenu oproti trénovaciemu datasetu. Cieľom bolo overiť robustnosť a schopnosť generalizácie modelov.

6 Výsledky

6.1 Priebeh trénovania

Oba modely konvergovali stabilne v priebehu 3 epoch. Trénovacia a validačná chyba (cross-entropy loss) klesala monotónne, pričom nebolo pozorované výrazné preučenie — validačná chyba kopírovala pokles trénovacej chyby. Validačná accuracy dosiahla plateau vo 3. epoche. CySecBERT vykazoval o niečo rýchlejší pokles validačnej straty v prvej epoche, čo korešponduje s jeho doménovou špecializáciou.

6.2 Výsledky na testovacej množine

Tabuľka 2 sumarizuje výsledky oboch modelov na testovacej množine.

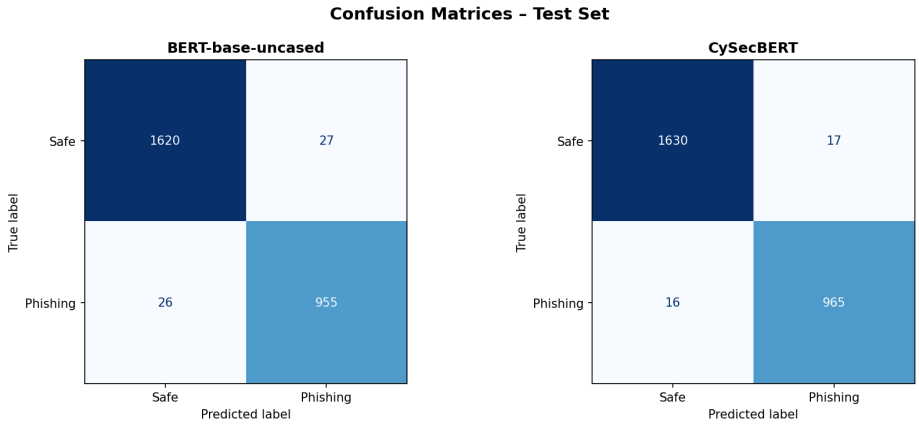
Tabuľka 2: Porovnanie modelov na testovacej množine.

Model	Accuracy	F1	Precision	Recall	ROC-AUC
BERT-base-uncased	0,9798	0,9730	0,9725	0,9735	0,9977
CySecBERT	0,9874	0,9832	0,9827	0,9837	0,9986
Δ (CySecBERT − BERT)	+0,0076	+0,0102	+0,0102	+0,0102	+0,0009

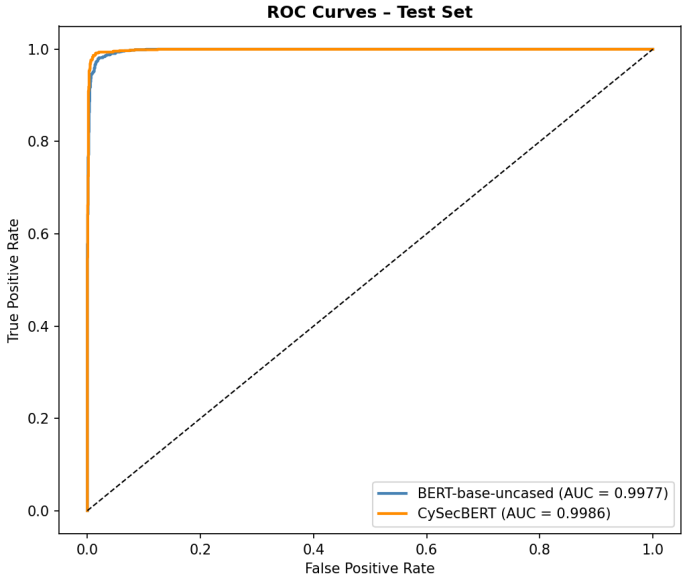
CySecBERT prekonáva BERT-base-uncased vo všetkých hodnotených metrikách. Najvýraznejší rozdiel je v skóre F1 (+1,02 pp).

6.3 Matice zámen a ROC krivky

Z matíc zámen (Obr. 1) vyplýva, že CySecBERT zaznamenal menej falošných negatív (16 vs. 27), čo je z pohľadu bezpečnosti kritickejší typ chyby — nezachytený phishing predstavuje väčšie riziko ako falošný poplach. ROC krivky (Obr. 2) potvrdzujú lepšiu celkovú diskriminačnú schopnosť CySecBERT-u.



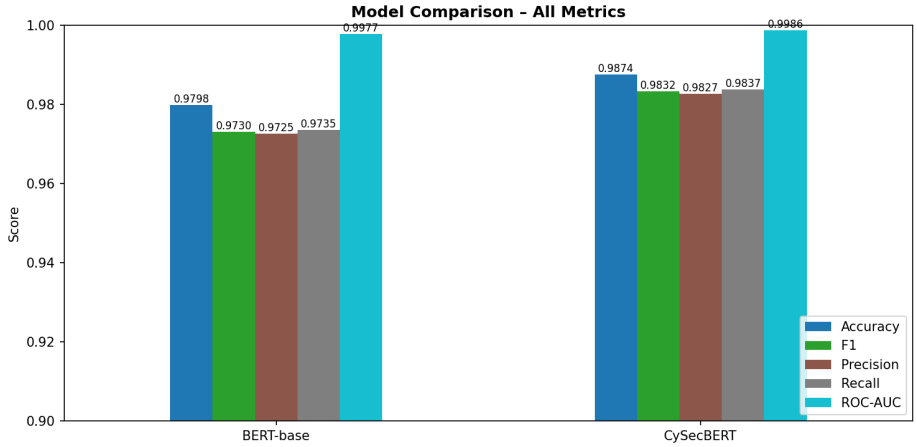
Obr. 1: Matice zámen pre oba modely na in-distribution testovacej množine. CySecBERT zaznamenal menej falošných negatív (16 vs. 27) aj falošných pozitív (17 vs. 27).



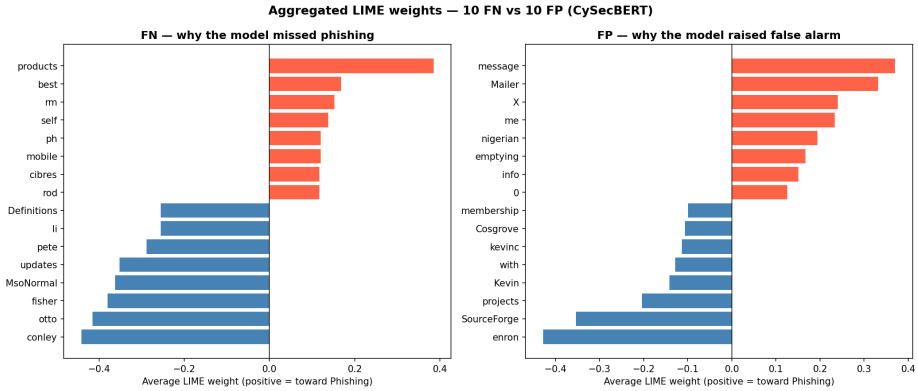
Obr. 2: ROC krivky na in-distribution testovacej množine. CySecBERT (AUC = 0,9986) mierne prevyšuje BERT (AUC = 0,9977).

6.4 Porovnanie metrík

Grafické porovnanie metrík (Obr. 3) naznačuje konzistentné zlepšenie CySecBERT-u naprieč všetkými hodnotenými metrikami.



Obr. 3: Porovnanie všetkých metrík oboch modelov na in-distribution testovacej množine.



Obr. 4: Agregované LIME váhy pre 10 FN a 10 FP vzoriek (CySecBERT, in-distribution dataset). Červené stĺpce tlačia predikciu smerom k Phishing, modré smerom k Safe.

6.5 Analýza chýb a LIME vysvetliteľnosť

Celkový počet chýb CySecBERT-u na testovacej množine bol nižší ako u BERT-u. Analýza rozdelenia chýb (Obr. 4):

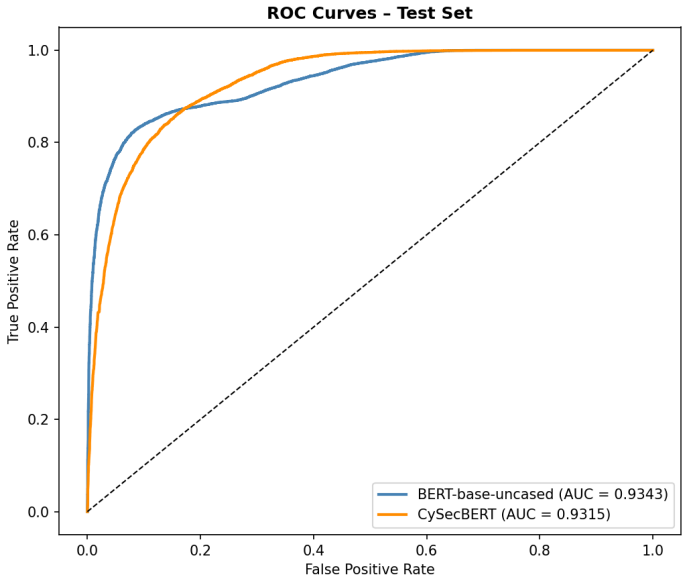
- **Falošné negatíva (FN)**: Phishingové e-maily predikované ako bezpečné. Väčšinou ide o sofistikované e-maily bez typických phishingových indikátorov. LIME ukázal, že model sa spoliehal na neutrálne osobné mená a miestne výrazy (napr. *conley*, *otto*, *fisher*), zatiaľ čo výrazy ako *products* a *best* tlačili predikciu nesprávne k phishingu.
- **Falošné pozitíva (FP)**: Legitímne e-maily predikované ako phishing. Model priradil vysoké váhy korporátnym výrazom typickým pre firemné notifi-

kácie (*message*, *Mailer*), ktoré zdieľa s phishingovými e-mailmi. Výrazy ako *enron* a *SourceForge* naopak správne tlačili predikciu k Safe.

6.6 Test generalizácie na externom datasete

Tabuľka 3: Výsledky oboch modelov na externom datasete (phishing_email.csv).

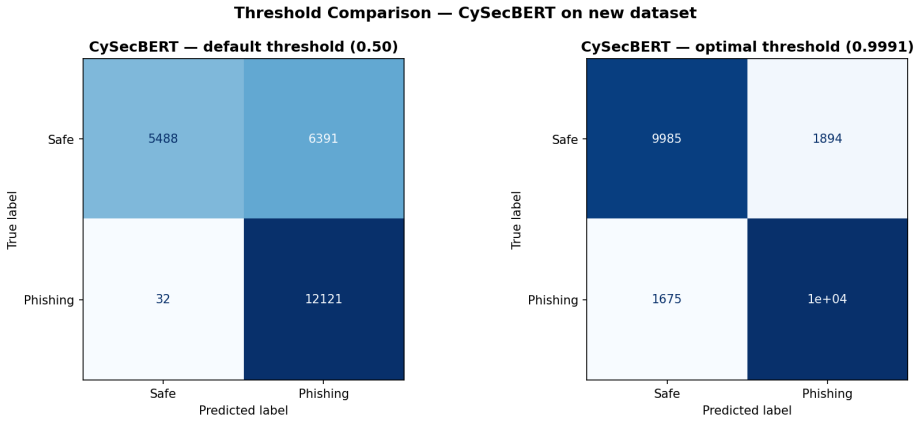
Model	Accuracy	F1	Precision	Recall	ROC-AUC
BERT-base-uncased	0,7654	0,8047	0,6950	0,9556	0,9343
CySecBERT	0,7327	0,7905	0,6548	0,9974	0,9315



Obr. 5: ROC krivky na externom datasete. BERT (AUC = 0,9343) mierne prevyšuje CySecBERT (AUC = 0,9315), čo naznačuje opačné poradie v porovnaní s in-distribution výsledkami.

Na externom datasete oba modely zaznamenali výrazný pokles accuracy (Tab. 3), avšak ROC-AUC zostalo nad 0,93 u oboch modelov, čo potvrdzuje, že naučené reprezentácie sú robustné. Presný pokles je spôsobený predovšetkým distribučnou zmenou — externý dataset obsahuje Enron-style firemné e-maily, ktoré sa výrazne líšia od trénovacích vzoriek.

Zaujímavé je, že CySecBERT dosiahol takmer perfektný Recall (0,9974), ale výrazne nižšiu Precision (0,6548) — model je silne naklonený triede Phishing, čo pri defaultnom prahu 0,5 generovalo 6 391 falošných pozitív. Na externom datasete BERT dosiahol lepšiu celkovú rovnováhu metrík.



Obr. 6: Porovnanie matíc zámen CySecBERT-u pri defaultnom prahu 0,50 a optimálnom prahu 0,9991 (Youden's J) na externom datasete.

6.7 Ladenie rozhodovacieho prahu

Aplikáciou Youden's J štatistiky sme identifikovali optimálny rozhodovací prah 0,9991 pre CySecBERT na externom datasete (Obr. 6). Pri tomto prahu sa počet falošných pozitív znížil z 6 391 na 1 894 (pokles o ≈70 %), za cenu nárastu falošných negatív z 32 na 1 675. Tento trade-off naznačuje, že voľba prahu závisí od konkrétneho nasadenia — v bezpečnostne kritickom prostredí je nižší Recall (viac FN) zvyčajne neprijateľný.

7 Kritická analýza a diskusia

7.1 Zhrnutie výsledkov

Výsledky potvrdzujú hypotézu, že doménovo špecifický model CySecBERT prevyšuje všeobecný BERT na in-distribution úlohe detekcie phishingových e-mailov. Doménová predtrénovacia fáza na kyberneticky orientovaných textoch poskytuje modelu lepšie pochopenie špeciálneho jazyka phishingových e-mailov.

Na externom datasete je situácia odlišná: BERT dosiahol lepší celkový výkon (vyššia Accuracy, Precision a rovnako vysoké ROC-AUC), zatiaľ čo CySecBERT bol výrazne naklonený triede Phishing. Toto naznačuje, že doménová špecializácia môže byť nevýhodou pri silnej distribučnej zmene.

7.2 Porovnanie s literatúrou

Dosiahnuté výsledky sú v súlade s trendom v literatúre, kde doménovo špecifické modely konzistentne prekonávajú všeobecné modely v špecializovaných NLP úlohách na in-distribution dátach. Napríklad BioBERT prekonáva BERT v biomedicínskych úlohách [3]. Avšak naše výsledky na externom datasete ukazujú, že doménová predtrénovaciu fáza nemusí automaticky zaručiť lepšiu generalizáciu.

7.3 Limitácie metrík

Napriek výbornej celkovej presnosti sú metriky závislé od rozloženia tried v testovacej množine. Reálne prostredie môže vykazovať iné pomery tried, čo ovplyvňuje praktickú použiteľnosť. Pre takéto scenáre by bolo vhodné sledovať aj *Average Precision (AP)*.

7.4 Diskusia o LIME explainability

LIME vysvetlenia sú lokálne aproximácie — neposkytnú globálny pohľad na rozhodovací proces modelu. Pre robustnejšiu interpretovateľnosť by bolo vhodné doplniť SHAP alebo gradient-based metódy (napr. Integrated Gradients).

8 Obmedzenia a možnosti ďalšej práce

8.1 Obmedzenia

1. **Dĺžka vstupu**: Maximálna dĺžka 128 tokenov môže orezať dlhé e-maily, čím sa stratia dôležité informácie z tela správy.
2. **Jednojazyčnosť**: Modely sú trénované prevažne na anglickom texte; detekcia phishingu v iných jazykoch by vyžadovala ďalšie adaptácie.
3. **Statický dataset**: Dataset nepokrýva neustále sa vyvíjajúce phishingové techniky — model by mohol zaostávať za novými útokmi.
4. **Absencia metadát**: Model pracuje len s obsahom textu; e-mailové hlavičky (sender, Reply-To, SPF/DKIM) obsahujú ďalšie silné signály.
5. **Kalibrácia prahu**: Defaultný prah 0,5 nie je optimálny pri distribučnej zmene, čo si vyžaduje dodatočné ladenie pri každom novom nasadení.

8.2 Možnosti ďalšej práce

- Otestovať modely s dlhším oknom kontextu (napr. Longformer, 512 tokenov).
- Vyskúšať iné architektúry: RoBERTa, DistilBERT, DeBERTa alebo väčšie kyberneticky orientované modely.
- Integrovať e-mailové metadáta (hlavičky, URL analýza) ako ďalšie vstupné príznaky.
- Testovanie v reálnom prostredí s kontinuálnym učením na nových phishingových kampaniach.
- Experimenty s krížovou validáciou na robustnejšie odhady výkonu.
- Nasadenie modelu do reálneho phishing filter pipeline.

9 Prínos jednotlivých členov tímu

- **Marek Homiak** — návrh architektúry riešenia, predspracovanie dát, implementácia tréningového pipeline, hyperparametre.
- **Marko Olejník** — reprodukovateľnosť, LIME vysvetliteľnosť, analýza chýb a ladenie prahu.
- **Hugo Juraj Bulinský** — tvorba prezentácie, TF-IDF analýza.
- **Adrián Polák** — vizualizácie, report.

Disclosure of Interests. Autori nemajú žiadne konkurenčné záujmy relevantné pre obsah tohto článku.

Literatúra

1. Bayer, M., Kuehn, P., Bhatt, R., Frey, C., Reuter, C.: CySecBERT: A domain-adapted language model for the cybersecurity domain. ACM Transactions on Privacy and Security **26**(2), 1–21 (2022)
2. Devlin, J., Chang, M.W., Lee, K., Toutanova, K.: BERT: Pre-training of deep bidirectional transformers for language understanding. Proceedings of NAACL-HLT pp. 4171–4186 (2019)
3. Lee, J., Yoon, W., Kim, S., Kim, D., Kim, S., So, C.H., Kang, J.: BioBERT: A pre-trained biomedical language representation model for biomedical text mining. Bioinformatics **36**(4), 1234–1240 (2020)
4. Liu, Z.: Phishing email dataset. `https://huggingface.co/datasets/zefang-liu/phishing-email-dataset` (2023), Hugging Face Hub
5. Ribeiro, M.T., Singh, S., Guestrin, C.: "Why should I trust you?": Explaining the predictions of any classifier. In: Proceedings of the 22nd ACM SIGKDD International Conference on Knowledge Discovery and Data Mining. pp. 1135–1144 (2016)
6. Vaswani, A., Shazeer, N., Parmar, N., Uszkoreit, J., Jones, L., Gomez, A.N., Kaiser, L., Polosukhin, I.: Attention is all you need. Advances in Neural Information Processing Systems **30** (2017)
7. Wolf, T., Debut, L., Sanh, V., Chaumond, J., Delangue, C., Moi, A., Cistac, P., Rault, T., Louf, R., Funtowicz, M., et al.: Transformers: State-of-the-art natural language processing. In: Proceedings of the 2020 Conference on Empirical Methods in Natural Language Processing: System Demonstrations. pp. 38–45 (2020)